

CYBER SECURITY COURSE

# Nessus Vulnerability Assessment

Professional Case Report 10

|                 |                                   |
|-----------------|-----------------------------------|
| Author          | Balsa Klikovac                    |
| Report date     | September 24, 2026                |
| Case ID         | CSC-2026-10                       |
| Discipline      | Vulnerability management          |
| Overall risk    | Critical                          |
| Evidence status | Confirmed by saved Nessus reports |

**Purpose**

Configure a safe scan policy, interpret findings by severity and convert scanner output into remediation priorities.

**Scope note**

This report documents work performed in an authorized training environment. Confirmed findings are separated from methodology and expected laboratory behavior.

## Executive Summary

Authenticated and unauthenticated vulnerability scans were performed against intentionally vulnerable bee-box, Metasploitable 2 and Metasploitable 3 systems. The lab demonstrates that scanner counts alone are not sufficient. Critical findings were prioritized because they combine remote reachability, low attack complexity and severe impact.

## Case Profile

|             |                                                                                                                                                               |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Scenario    | Authenticated and unauthenticated vulnerability scans were performed against intentionally vulnerable bee-box, Metasploitable 2 and Metasploitable 3 systems. |
| Environment | Nessus assessment of bee-box 192.168.145.133, Metasploitable 2 at 192.168.145.132 and Windows Server 2008 R2 at 192.168.56.105.                               |
| Tools       | Tenable Nessus, tcpdump, CVSS, CVE analysis, Service validation                                                                                               |

## Methodology

I used the following sequence to keep the analysis repeatable and to separate observation from interpretation.

1. Reviewed scan policy, credentials, plugins and safe-check settings.
2. Executed scans in the isolated lab and monitored traffic.
3. Validated critical findings against service and operating-system context.
4. Prioritized remediation by exploitability, exposure and business impact.

## Technical Findings

| ID  | Finding             | Risk     | Evidence and analysis                                                                                                                  |
|-----|---------------------|----------|----------------------------------------------------------------------------------------------------------------------------------------|
| F01 | Metasploitable 2    | Critical | Scan identified 9 critical, 7 high, 25 medium and 8 low findings, including an unauthenticated bind shell and unsupported Ubuntu 8.04. |
| F02 | Metasploitable 3    | Critical | Scan identified 14 critical, 23 high, 29 medium and 2 low findings, including BlueKeep and MS17-010 exposure.                          |
| F03 | bee-box             | Critical | Scan identified critical legacy SSL, Samba and application vulnerabilities; one summary contained 5 critical and 10 high findings.     |
| F04 | Systemic root cause | Critical | Unsupported operating systems and obsolete services created multiple overlapping exploitation paths.                                   |

## Representative Commands and Actions

The following commands or analysis actions represent the core of the practical workflow.

```
sudo service nessusd start
```

```
sudo tcpdump -nn net <target_ip>  
Export scan results for evidence retention
```

## Risk Assessment

| Risk                  | Level    | Operational impact                              |
|-----------------------|----------|-------------------------------------------------|
| Remote compromise     | Critical | Multiple unauthenticated attack paths           |
| Weak cryptography     | High     | Legacy SSL and weak keys reduce confidentiality |
| Unsupported platforms | Critical | No security fixes are available                 |

## Recommendations

1. Remove unsupported systems from production networks.
2. Patch MS17-010, BlueKeep and exposed services before lower-severity items.
3. Disable legacy SSL/TLS and regenerate weak cryptographic material.
4. Repeat scanning after remediation and retain before-and-after evidence.

## Knowledge Demonstrated

- Scanner configuration
- Vulnerability validation
- Risk prioritization
- Executive reporting

## Conclusion

The lab demonstrates that scanner counts alone are not sufficient. Critical findings were prioritized because they combine remote reachability, low attack complexity and severe impact.

## Hands On Lab Practical 10

Completed as part of the authorized cyber security course practical work.